CONFIDENTIAL SECURITY DOCUMENT

Active Compromise Forensic Report

Example System

Incident investigation & artifact analysis

Document Type	Incident / active-compromise forensic assessment
Subject System	Example System
Trigger	[FILL: e.g. Artifacts discovered during an unrelated static assessment]
Investigation Date	1 January 2030
Artifacts Found	[FILL: N (e.g. 1 webshell, 1 backdoor, 2 staged files)]
Overall Risk	CRITICAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive incident details and must not be shared outside authorised personnel responsible for containment and remediation.

Scope of analysis: [FILL: One or two sentences describing how the artifacts were found and analysed, e.g. "a read-only filesystem review of the deployed web application; no artifact was executed or modified, and no live network traffic was captured."]

Warning: This report describes a live, exploitable compromise. Treat every credential and access path referenced here as burned until rotated, and coordinate takedown/rotation with the incident-response process before wide circulation.

1

1 Table of Contents

1 Table of Contents 1

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Scope Note . . . 2
2.3 Overall Risk Rating . . . 2
2.4 Artifacts at a Glance . . . 2

3 Scope & Methodology 3
3.1 Subject & Scope . . . 3
3.2 Approach . . . 3

4 Attack Mechanism 4

5 Webshell & Artifact Inventory 5
5.1 Finding IC-01 — [FILL: Short title, e.g. "OS Command-Execution Webshell"] 5
5.2 Consolidated Artifact List . . . 5

6 Artifact Timeline & Interpretation 6
6.1 Timeline . . . 6
6.2 Detailed Timeline . . . 6

7 Database / Data Exposure 7
7.1 Finding IC-03 — [FILL: e.g. "Cleartext Database Credentials Reachable via RCE"] . . . 7
7.1.1 Evidence . . . 7
7.1.2 Data at Risk . . . 7

8 Indicators of Compromise (IOCs) 8
8.1 On-Disk Indicators . . . 8
8.2 Network / HTTP Indicators . . . 8
8.3 Host Indicators . . . 9

9 Business Impact 10

10 Recommendations 11

11 Appendix A — Full Artifact Paths 12

12 Appendix B — Credential Rotation Checklist 12

2 Executive Summary

Overview

During [FILL: describe the trigger, e.g. "a routine static security assessment"] of Example System, [FILL: N] artifacts consistent with an active or historical compromise were discovered: [FILL: one clause per artifact type, e.g. "an unauthenticated command-execution webshell, a hardcoded authentication backdoor, and staged non-application files in an upload directory"].

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict, e.g. "a live, functional webshell exists on the production host today"].

Headline conclusions:

- [FILL: Headline finding 1, e.g. "a working unauthenticated command shell exists on the live system"]
- [FILL: Headline finding 2]
- [FILL: Headline finding 3]

Scope Note

[FILL: State clearly what is and is not covered - e.g. any artifact intentionally introduced by the assessment team itself is excluded from the inventory below; access logs outside the reviewed tree were not available.]

Overall Risk Rating

CRITICAL

Artifacts at a Glance

ID	Severity	Artifact
IC-01	CRITICAL	[FILL: e.g. Unauthenticated command-execution webshell]
IC-02	HIGH	[FILL: e.g. Hardcoded authentication backdoor]

3 Scope & Methodology

Subject & Scope

Item	Detail
System	Example System
Investigation type	[FILL: e.g. Read-only filesystem/artifact review - discovery only, nothing executed or modified]
Data sources	[FILL: e.g. Deployed application source tree; filesystem mtimes; no live network capture]

Approach

1. **Artifact discovery.** [FILL: How suspicious files/backdoors were located - e.g. pattern search for exec/eval sinks, unusual file extensions or permissions, filename anomalies.]
2. **Characterisation.** [FILL: How each artifact was analysed to determine what it does, without executing it.]
3. **Timeline reconstruction.** [FILL: How dates/ordering were established - e.g. filesystem mtimes - and the confidence caveats that come with that method.]
4. **Impact & IOC synthesis.** Findings were compiled into a consolidated inventory, a timeline, and a set of indicators of compromise for detection/hunting.

Caveat. [FILL: Note any limitation, e.g. "filesystem mtimes are attacker-influenceable and bound presence, not necessarily the moment of first abuse."]

4 Attack Mechanism

[FILL: One or two paragraphs explaining the technical mechanism: what the artifact does when invoked, what privileges it runs with, and why it is reachable by an attacker (e.g. no authentication check, world-writable permissions, served from a web-accessible directory).]

[FILL: Illustrative snippet title - no real hostnames/paths]

```
// minimal illustrative pseudocode showing the mechanism, not the real file contents --
    ↪ replace with your own
```

CRITICAL — Key Takeaway

[FILL: One paragraph stating plainly what capability this grants an attacker right now.]

5 Webshell & Artifact Inventory

This section catalogues every malicious / suspicious artifact found, with representative code and a description of what each does. Sizes are in bytes; times are filesystem mtimes (local).

Finding IC-01 — [FILL: Short title, e.g. "OS Command-Execution Webshell"]

Finding Metadata

ID / Severity	IC-01 | CRITICAL
File	[FILL: relative/path/to/artifact] ([FILL: size bytes], mtime [FILL: YYYY-MM-DD])
Category	[FILL: e.g. OS command-execution webshell]
Authentication	[FILL: None]
Endpoint	[FILL: http://host/path?param=value]

[FILL: One paragraph describing the artifact in plain language: what interface it presents, what it does with attacker input, and why there is no auth check.]

[FILL: path/to/artifact - description of behaviour]

```
// minimal illustrative reconstruction of the artifact's logic, not the verbatim file --
    ↪ replace with your own
```

CRITICAL — Key Takeaway

[FILL: One paragraph: how long this has plausibly been present, and the single worst thing an attacker can do with it right now.]

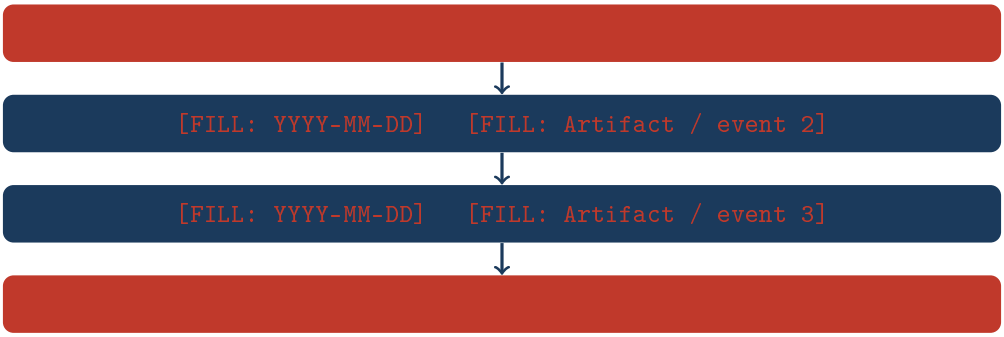
Consolidated Artifact List

File	mtime	ID	Behaviour
[FILL: path]	[FILL: date]	IC-01	[FILL: one-line behaviour summary]
[FILL: path]	[FILL: date]	IC-02	[FILL: one-line behaviour summary]

6 Artifact Timeline & Interpretation

[FILL: One paragraph interpreting the overall shape of the timeline below.]

Timeline



Detailed Timeline

Date	Artifact / Phase	Evidence
[FILL: YYYY-MM-DD]	[FILL: Phase name]	[FILL: One-line evidence description]
[FILL: YYYY-MM-DD]	[FILL: Phase name]	[FILL: One-line evidence description]

Interpretation

[FILL: One paragraph stating the high-confidence conclusions and, separately, what remains uncertain given the evidence available (e.g. mtimes bound presence, not first abuse).]

7 Database / Data Exposure

Finding IC-03 — [FILL: e.g. "Cleartext Database Credentials Reachable via RCE"]

Finding Metadata			
ID	IC-03	**Severity**	**CRITICAL**
Category	[FILL: Credential exposure / data at risk]	**Status**	[FILL: Reachable now]
Backends	[FILL: e.g. PostgreSQL, Redis]	**Action**	Rotate all credentials

Evidence

1. **Credentials are stored in cleartext.** [FILL: Describe the config file / location and how many accounts/hosts are affected. Do not include the actual secret values. *Values are withheld from this report per the rules of engagement.*]
2. **Reachability.** [FILL: Explain how the credential file becomes readable given the other artifacts in this report (e.g. via the webshell in IC-01).]
3. **Capability.** [FILL: State what an actor can do with OS access plus these credentials.]

CRITICAL — Key Takeaway

[FILL: One paragraph: because a live foothold and reachable cleartext credentials coexist, every credential reachable from this host must be treated as burned. State the rotation scope and the follow-up review needed (unauthorised accounts, unexpected logons, schema changes).]

Data at Risk

[FILL: Name the system this supports and list, at a category level (not specific records), what kinds of sensitive data are exposed if this path is exploited - e.g. personal records, financial data, credentials for other systems.]

- [FILL: Data category 1]
- [FILL: Data category 2]

8 Indicators of Compromise (IOCs)

The following indicators allow detection of this compromise on the live host and across other instances of the application.

On-Disk Indicators

- **Known artifacts:** [FILL: path/to/artifact] and any file matching [FILL: describe the general pattern, e.g. "an unexpected .jsp/.php under an upload/attachment directory"].
- **Filename tokens:** [FILL: list suspicious tokens, e.g. dot-named files, double extensions, null bytes, oddly-cased extensions].
- **Content markers:** [FILL: list suspicious code markers, e.g. Runtime.exec, ProcessBuilder, base64 decode-and-eval patterns].

Read-only on-disk detection sweep

```
# illustrative grep/find command for hunting the same pattern elsewhere -- replace with
    ↪ your own
```

Network / HTTP Indicators

[FILL: Note whether access logs were available. If not available in this source tree, say so and list what to pull and search for.]

- [FILL: e.g. GET requests to the known artifact path, especially with suspicious parameters]
- [FILL: e.g. POST/multipart uploads with executable-looking filenames]
- [FILL: e.g. outbound connections initiated by the application process]

Host Indicators

- [FILL: e.g. unexpected database logons sourced from the application host]
- [FILL: e.g. modifications to authorized_keys, cron, or service startup scripts]
- [FILL: e.g. new or modified files anywhere under the web root, especially world-writable ones]

9 Business Impact

[FILL: One or two paragraphs on realistic worst-case impact: data exposed, systems reachable, regulatory/contractual exposure, and reputational considerations.]

Impact Area	Detail
[FILL: e.g. Data confidentiality]	[FILL: What could be read]
[FILL: e.g. Data integrity]	[FILL: What could be modified]
[FILL: e.g. Availability]	[FILL: Any disruption risk]

Evidence of actual exploitation. [FILL: State plainly whether there is evidence the artifact was actually used maliciously (vs. only being present and exploitable), and the confidence level of that assessment.]

10 Recommendations

Priority	Recommendation
Immediate (containment)	[FILL: e.g. Remove the identified artifact(s); rotate every credential reachable from the host.]
Short-term	[FILL: e.g. Close the delivery channel that allowed artifacts to be planted (upload validation, file-type allowlisting).]
Long-term	[FILL: e.g. File-integrity monitoring on web-served directories; centralised auth filter; periodic artifact sweeps.]

[FILL: Optional closing paragraph on suggested follow-up: a fuller forensic timeline using access logs, a broader sweep of similar deployments, or a retest after remediation.]

11 Appendix A — Full Artifact Paths

Path	ID
[FILL: path/to/artifact]	IC-01
[FILL: path/to/artifact]	IC-02

12 Appendix B — Credential Rotation Checklist

- [FILL: Credential/system 1 - owner, rotation deadline]
- [FILL: Credential/system 2 - owner, rotation deadline]

This report is **CONFIDENTIAL** — Restricted to authorised personnel only
Example System — Incident Forensic Report — 1 January 2030